

DISEÑO DE SEGURIDAD PARA EL SISTEMA DE DETECCIÓN DE ANOMALÍAS

MediData Health - Proyecto de Minería de Datos

1. OBJETIVOS DEL DISEÑO DE SEGURIDAD

#	Objetivo	Descripción
1	Proteger la confidencialidad	Garantizar que los datos de pacientes y empleados solo sean accesibles por personal autorizado.
2	Asegurar la integridad	Prevenir modificaciones no autorizadas de los datos de acceso y los modelos.
3	Garantizar la disponibilidad	Asegurar que el sistema de detección de anomalías esté operativo cuando sea necesario.
4	Cumplir con HIPAA	Implementar controles que cumplan con los requisitos de la Ley de Portabilidad y Responsabilidad del Seguro Médico (HIPAA).
5	Auditabilidad	Registrar todas las acciones relevantes para facilitar auditorías internas y externas.

2. POLÍTICAS DE SEGURIDAD ESPECÍFICAS

2.1 Política de Seudonimización y Desidentificación

Aspecto	Descripción
Método	Hashing con sal (SHA-256 + salt único por proyecto) para generar identificadores únicos.
Capa de aplicación	Laseudonimización se aplicará en el origen de los datos (antes de almacenar) y en la capa de API al momento de servir los datos.

Aspecto	Descripción
Datos a seudonimizar	id_usuario, id_paciente, nombre_completo, número_de_seguro_social, dirección
Control de reversibilidad	La tabla de mapeo (identificador real ↔ seudónimo) se almacenará en una base de datos con cifrado y acceso restringido a solo dos administradores.
Validación de re-identificación	Se realizarán pruebas periódicas para verificar que, cruzando campos aparentemente idénticos, no sea posible re-identificar a un paciente o empleado.

Ejemplo de función de seudonimización en Python:

```
import hashlib
import os

def seudonimizar(texto, salt=None):
    """Aplica hashing SHA-256 con salt para seudonimizar datos."""
    if salt is None:
        salt = os.environ.get('SECRET_SALT', 'default_salt')
    return hashlib.sha256(f"{texto}{salt}".encode()).hexdigest()
```

2.2 Política de Control de Acceso (RBAC)

Rol	Permisos	Acceso a Datos
Administrador de Seguridad	Gestión de usuarios, auditoría, configuración del sistema, respuesta a incidentes.	Datos seudonimizados completos + logs de auditoría.
Analista de Datos	Ejecución de modelos, visualización de dashboards,	Solo datos seudonimizados. Sin acceso a la tabla de mapeo.

Rol	Permisos	Acceso a Datos
	generación de reportes.	
Auditor Interno	Consulta de logs de auditoría, revisión de cumplimiento.	Logs de acceso y metadatos. Sin datos de pacientes.
Ejecutivo / Director	Visualización de dashboards resumidos y reportes de alto nivel.	Datos agregados y estadísticas. Sin acceso a registros individuales.
Usuario de Sistema (módulo hospitalario)	Acceso solo a los historiales de pacientes bajo su responsabilidad directa.	Datos de pacientes específicos, con registro de auditoría de cada acceso.

2.3 Política de Gestión de Logs y Auditoría

Aspecto	Especificación
Eventos a registrar	• Inicios de sesión (exitosos y fallidos) • Cambios en permisos de usuarios • Alertas generadas por el modelo • Accesos a datos de pacientes • Ejecución de reportes • Modificaciones en la configuración del sistema
Formato de logs	JSON estructurado con: timestamp, id_usuario_seudonimizado, accion, modulo_origen, direccion_ip, resultado.
Retención	7 años (cumpliendo con HIPAA que exige retención de registros de acceso por al menos 6 años).

Aspecto	Especificación
Protección de logs	Los logs se almacenan en un sistema de SIEM (Security Information and Event Management) con cifrado y acceso restringido.
Monitorio activo	Alertas automáticas ante: intentos de acceso fallidos repetidos, accesos fuera de horario laboral, o intentos de escalación de privilegios.

3. PLAN DE RESPUESTA A INCIDENTES

3.1 Clasificación de Incidentes

Nivel	Descripción	Ejemplo
Nivel 1 - Bajo	Eventos atípicos que no confirman un acceso indebido.	Alerta del modelo por volumen inusual de accesos.
Nivel 2 - Medio	Actividad sospechosa confirmada por el analista.	Acceso a historial de un paciente sin justificación clínica.
Nivel 3 - Alto	Filtración de datos confirmada o acceso no autorizado a gran escala.	Acceso masivo a historiales de pacientes desde una IP externa.
Nivel 4 - Crítico	Impacto significativo en la privacidad de los pacientes, requiere notificación legal.	Exposición de datos de más de 500 pacientes.

3.2 Protocolo de Notificación a Autoridades y Pacientes

Acción	Responsable	Plazo
Notificar al Privacy Officer	Equipo de Seguridad	Inmediato

Acción	Responsable	Plazo
Notificar a pacientes afectados	Privacy Officer	60 días desde la detección
Notificar a HHS (más de 500 pacientes)	Privacy Officer	60 días desde la detección
Notificar a la prensa/comunicado público	Directorio / Comunicaciones	A discreción del directorio
Reporte final a autoridades	Privacy Officer + Asesor Legal	30 días después del cierre del incidente

4. MATRIZ DE CONTROLES DE SEGURIDAD (ALINEACIÓN CON HIPAA)

Control de Seguridad	Implementación	Cumple HIPAA
Access Control	Autenticación multifactor (MFA), RBAC, principio de mínimo privilegio.	✓ \$164.312(a)(1)
Audit Controls	Logs detallados de todos los accesos y acciones.	✓ \$164.312(b)
Integrity Controls	Hashing de archivos, controles de versión, firmas digitales en modelos.	✓ \$164.312(c)(1)
Transmission Security	Cifrado TLS 1.3 para todas las comunicaciones.	✓ \$164.312(e)(1)
Encryption at Rest	AES-256 para bases de datos, backups y Data Lake.	✓ \$164.312(a)(2)(iv)

Control de Seguridad	Implementación	Cumple HIPAA
Authentication	MFA + contraseñas robustas + política de expiración.	✓ \$164.312(d)
Device and Media Controls	Gestión de dispositivos autorizados, bloqueo remoto.	✓ \$164.310(d)
Security Incident Procedures	Plan de respuesta a incidentes documentado.	✓ \$164.308(a)(6)
Contingency Plan	Plan de recuperación ante desastres y backups.	✓ \$164.308(a)(7)
Evaluation	Auditorías de seguridad periódicas (anuales).	✓ \$164.308(a)(8)

5. RECOMENDACIONES ADICIONALES DE SEGURIDAD

5.1 Seguridad en el Ciclo de Vida del Modelo

Fase	Medida de Seguridad
Entrenamiento	Datos de entrenamiento seudonimizados y aislados en un entorno seguro (sandbox). Sin acceso a internet.
Validación	Validación cruzada con datos de prueba también seudonimizados y cifrados.
Despliegue	El modelo se despliega en contenedores Docker con políticas de red restrictivas.
Monitoreo	Monitoreo continuo del rendimiento del modelo para detectar desviaciones (drift).

Fase	Medida de Seguridad
Actualización	El modelo se reentrena con datos nuevos de forma programada, siempre bajo supervisión.

5.2 Gestión de Vulnerabilidades

text

PROGRAMA DE GESTIÓN DE VULNERABILIDADES		
• Escaneo automático de vulnerabilidades (mensual):		
- Análisis de dependencias de Python (pip-audit)		
- Escaneo de contenedores (Trivy, Clair)		
- Análisis de código estático (Bandit, SonarQube)		
• Pruebas de penetración (anual):		
- Contratar a un equipo externo para pentesting.		
• Gestión de parches:		
- Aplicar parches de seguridad en menos de 7 días.		
- Mantener un inventario de activos actualizado.		

5.3 Capacitación y Concienciación

Grupo	Capacitación	Frecuencia
Todo el personal	Privacidad de datos, identificación de phishing, buenas prácticas de seguridad.	Anual
Desarrolladores	Seguridad en el desarrollo (OWASP Top 10), cifrado, manejo de datos sensibles.	Semestral

Grupo	Capacitación	Frecuencia
Analistas de Datos	Manejo seguro de datos seudonimizados, ética en el uso de datos.	Semestral
Equipo de Seguridad	Amenazas avanzadas, respuesta a incidentes, forense digital.	Trimestral

6. CHECKLIST DE IMPLEMENTACIÓN DE SEGURIDAD

#	Elemento	Estado	Responsable
1	Implementar MFA en todos los accesos al sistema.	☐ Pendiente	Arquitecto de Seguridad
2	Configurar RBAC con roles definidos.	☐ Pendiente	Arquitecto de Seguridad
3	Implementar seudonimización en el origen de los datos.	☐ Pendiente	Data Engineer
4	Cifrar base de datos y Data Lake (AES-256).	☐ Pendiente	DBA / DevOps
5	Configurar TLS 1.3 en todas las comunicaciones.	☐ Pendiente	DevOps
6	Desplegar SIEM para gestión de logs y alertas.	☐ Pendiente	Equipo de Seguridad
7	Crear y aprobar el plan de respuesta a incidentes.	☐ Pendiente	Director de Seguridad
8	Realizar primera auditoría de seguridad interna.	☐ Pendiente	Auditor Interno

#	Elemento	Estado	Responsable
9	Desarrollar programa de capacitación en seguridad.	☐ Pendiente	HR / Seguridad
10	Implementar escaneo de vulnerabilidades (mensual).	☐ Pendiente	DevOps / Seguridad
11	Establecer política de backup encriptado.	☐ Pendiente	DBA / DevOps
12	Realizar prueba de penetración (pentest) externa.	☐ Pendiente	Tercero contratado

7. PRESUPUESTO ESTIMADO DE SEGURIDAD

Recurso / Herramienta	Costo Estimado (USD)	Periodicidad
SIEM (ej. Splunk, ELK)	\$15,000 - \$50,000	Anual
MFA (ej. Okta, Duo)	\$5,000 - \$20,000	Anual
Herramientas de cifrado	\$5,000 - \$10,000	Único
Pentesting externo	\$10,000 - \$30,000	Anual
Capacitación en seguridad	\$5,000 - \$15,000	Anual
EDR / Antivirus (licencias)	\$10,000 - \$25,000	Anual
TOTAL ESTIMADO	\$50,000 - \$150,000	Anual

8. ROLES Y RESPONSABILIDADES DE SEGURIDAD

Rol	Responsabilidades
Chief Information Security Officer (CISO)	Liderazgo de la estrategia de seguridad, aprobación de políticas, reporte al directorio.
Privacy Officer	Cumplimiento de HIPAA, manejo de brechas de datos, relación con autoridades.
Arquitecto de Seguridad	Diseño de la arquitectura de seguridad, selección de herramientas, revisión de implementaciones.
Equipo de Respuesta a Incidentes (CSIRT)	Investigación y contención de incidentes, forense digital.
Data Steward	Custodia de datos, aplicación de políticas de seudonimización y acceso.
Auditor Interno	Revisión periódica de cumplimiento, generación de reportes de auditoría.
Desarrolladores	Implementación de controles de seguridad en el código.